Day 8 | 数据安全（Ch7）

生成日期：2026-11-11 | 建议用时90分钟 | 蓝色=重点；橙色=易错；绿色=任务。

一、今日学习目标

说出本领域目的并划清与相近领域的职责边界（15分钟）

为两个业务场景选择处理措施并解释取舍（25分钟）

列出角色、交付物及可验证指标（15分钟）

完成8题，逐题解释最佳答案和干扰选项（作答15分钟、复盘20分钟）

二、核心知识点精讲

目的与边界

Data Security：以与风险相称的控制保护机密性、完整性和可用性，并落实授权使用。先明确业务痛点、风险与范围，再确定活动；不要把工具上线等同于目标达成。

主要活动与实施路径

从需求和现状出发，形成可批准的规则与设计，再实施、验证、监控和改进。以下场景逐一说明如何把原则变成判断：

场景1：分析师只需汇总销售额却得到全库管理员权限，应采用什么

按任务授予最小必要权限。最小权限减少暴露面；方便不等于必要，共享密码及关日志破坏追责。 实施时应记录依据、责任人与验证结果，避免只作一次性口头决定。

场景2：离职员工账号仍能读取客户信息，应优先做什么

按流程撤销访问并评估已发生的访问。撤权应及时且检查风险；排版和压缩无助于授权，长期等待扩大暴露。 实施时应记录依据、责任人与验证结果，避免只作一次性口头决定。

场景3：用户身份已通过验证，是否可读取全部数据

仍须检查对资源和操作的授权。认证回答是谁，授权回答能做什么；地点和表名都不自动提供访问权。 实施时应记录依据、责任人与验证结果，避免只作一次性口头决定。

场景4：加密数据的密钥与密文放在同一公开目录，主要问题是什么

密钥管理削弱加密保护。加密依赖密钥保护；公开存放可能使攻击者同时获取解密条件。 实施时应记录依据、责任人与验证结果，避免只作一次性口头决定。

场景5：一个人既申请又批准自己的敏感访问，应加强什么

职责分离与独立审批。职责分离减少滥用与冲突；删日志和取消审批削弱控制，磁盘不解决授权。 实施时应记录依据、责任人与验证结果，避免只作一次性口头决定。

场景6：审计日志需要支持调查，重要属性是什么

可追踪且防止未经授权篡改。可信日志需身份、事件和时间等信息并保护完整性；任改和缺时间降低证据价值。 实施时应记录依据、责任人与验证结果，避免只作一次性口头决定。

场景7：数据始终准确但系统持续不可访问，哪项受损

可用性。安全同时覆盖可用性；准确不能补偿服务不可用，也不能据此推断泄密。 实施时应记录依据、责任人与验证结果，避免只作一次性口头决定。

场景8：发现疑似客户信息泄露，最佳起点是什么

按响应流程控制风险并保全证据及升级。响应需控制、证据和授权沟通；删证据、未经核实发布与扩散会增加伤害。 实施时应记录依据、责任人与验证结果，避免只作一次性口头决定。

角色与问责

所有者确认分类及授权需求；安全人员设计控制；技术保管者实施；审计或监督人员检查证据。具体岗位名称因组织而异，判断职责时应查看授权和工作内容。

交付物与验收

数据分类方案、访问矩阵、授权审批、审计日志、事件响应计划。每份交付物应有维护责任、适用范围、审批或复核方式，确保可以被实际使用。

指标与业务结果

权限复核覆盖率、撤权时效、控制测试结果、事件处理时长。这些是原创教学示例，不是DAMA统一要求的阈值；应结合业务目的解释变化原因。

与其他领域协作

治理批准责任与政策，元数据标识敏感性，运营执行控制；伦理进一步检查用途与潜在伤害。案例为原创简化情境，实际工作需进一步评估组织约束。

【重点】本资料以DMBOK2相应章节为框架，结合公开材料作原创辅导，不替代合法教材，也不复制教材整章。

三、高频考点与易错点

“高频”仅指重点复习建议，不代表官方出题频率。

【易错】分析师只需汇总销售额却得到全库管理员权限，应采用什么：按任务授予最小必要权限。最小权限减少暴露面；方便不等于必要，共享密码及关日志破坏追责。

【易错】离职员工账号仍能读取客户信息，应优先做什么：按流程撤销访问并评估已发生的访问。撤权应及时且检查风险；排版和压缩无助于授权，长期等待扩大暴露。

【易错】用户身份已通过验证，是否可读取全部数据：仍须检查对资源和操作的授权。认证回答是谁，授权回答能做什么；地点和表名都不自动提供访问权。

【易错】加密数据的密钥与密文放在同一公开目录，主要问题是什么：密钥管理削弱加密保护。加密依赖密钥保护；公开存放可能使攻击者同时获取解密条件。

【易错】一个人既申请又批准自己的敏感访问，应加强什么：职责分离与独立审批。职责分离减少滥用与冲突；删日志和取消审批削弱控制，磁盘不解决授权。

【易错】审计日志需要支持调查，重要属性是什么：可追踪且防止未经授权篡改。可信日志需身份、事件和时间等信息并保护完整性；任改和缺时间降低证据价值。

四、实战练习

原创模拟题，非官方真题。8道单选题，每题四选一，仅一个最佳答案。训练用时15分钟，另留20分钟复盘；此处不是官方考试时限。

题目

1. 分析师只需汇总销售额却得到全库管理员权限，应采用什么？

A. 按任务授予最小必要权限

B. 为方便继续保留全部权限

C. 公开管理员密码

D. 关闭访问日志

2. 离职员工账号仍能读取客户信息，应优先做什么？

A. 等年度盘点再说

B. 按流程撤销访问并评估已发生的访问

C. 仅改变报表样式

D. 只压缩数据文件

3. 用户身份已通过验证，是否可读取全部数据？

A. 只要在办公室就可以

B. 只要知道表名就可以

C. 仍须检查对资源和操作的授权

D. 当然可以读取全部

4. 加密数据的密钥与密文放在同一公开目录，主要问题是什么？

A. 字体过小

B. 逻辑模型实体太少

C. 备份文件名太长

D. 密钥管理削弱加密保护

5. 一个人既申请又批准自己的敏感访问，应加强什么？

A. 职责分离与独立审批

B. 让其同时删除日志

C. 直接取消全部审批

D. 只增加磁盘

6. 审计日志需要支持调查，重要属性是什么？

A. 只记录系统颜色

B. 可追踪且防止未经授权篡改

C. 任何人可随意修改

D. 不记录时间

7. 数据始终准确但系统持续不可访问，哪项受损？

A. 必然是机密性

B. 只是主数据匹配

C. 可用性

D. 只有术语一致性

8. 发现疑似客户信息泄露，最佳起点是什么？

A. 删除所有日志隐藏问题

B. 自行对外发布未经核实结论

C. 继续扩散数据以便讨论

D. 按响应流程控制风险并保全证据及升级

答案与解析

1. A | 数据安全（Ch7） | 最小权限减少暴露面；方便不等于必要，共享密码及关日志破坏追责。

2. B | 数据安全（Ch7） | 撤权应及时且检查风险；排版和压缩无助于授权，长期等待扩大暴露。

3. C | 数据安全（Ch7） | 认证回答是谁，授权回答能做什么；地点和表名都不自动提供访问权。

4. D | 数据安全（Ch7） | 加密依赖密钥保护；公开存放可能使攻击者同时获取解密条件。

5. A | 数据安全（Ch7） | 职责分离减少滥用与冲突；删日志和取消审批削弱控制，磁盘不解决授权。

6. B | 数据安全（Ch7） | 可信日志需身份、事件和时间等信息并保护完整性；任改和缺时间降低证据价值。

7. C | 数据安全（Ch7） | 安全同时覆盖可用性；准确不能补偿服务不可用，也不能据此推断泄密。

8. D | 数据安全（Ch7） | 响应需控制、证据和授权沟通；删证据、未经核实发布与扩散会增加伤害。

五、优质资料与链接

以下来源均已读取正文；访问日期2026-11-11。英文关键术语保留，中文解释为原创归纳。

[1] DAMA-DMBOK Framework：官方项目：核对领域目的及跨领域关系；场景与题目为原创。

https://www.damadmbok.org/dmbok-framework

[2] DMBOK 2.0 Revision：官方项目：核对修订范围，不把旧版表述误作新增规则。

https://www.damadmbok.org/dmbok2-revisions

[3] DAMA-DMBOK介绍：DAMA官方：框架定位及合法教材入口，非完整教材正文。

https://dama.org/learning-resources/dama-data-management-body-of-knowledge-dmbok/

六、今日任务清单与明日预告

【任务】阅读合法教材对应章节，按“目的、活动、角色、交付物、指标、协作”写出一页提纲。

【任务】先作答再看解析，记录日期、学习日、题号、知识领域、是否正确和错因；每道错题说明一个干扰选项为何错误。

【任务】回顾前1个学习日Day7：复述该日目的、一个交付物及与本领域的联系；回顾前3个学习日Day5：复述该日目的、一个交付物及与本领域的联系；回顾前7个学习日Day1：复述该日目的、一个交付物及与本领域的联系。没有实际答题记录时不判断个人弱点。

【任务】当前无已填写答题记录，采用默认复习方案；尚未识别个人薄弱领域。

【重点】练习成绩只用于诊断。模拟题80%可作为训练目标，不等同于官方考试通过概率。

明日预告：数据集成和互操作（Ch8）